

Cyber Tabletop Exercise

University MFA Phishing and Student Records Exposure

Organization: Lakeside State University | Sector: Education

Generated from STIX 2.1 source bundle | Exercise date: to be scheduled

Facilitator-ready package

This tabletop exercise is designed for executive, operational, legal/privacy, communications, and technical teams. It uses a fictional but plausible university identity-provider phishing scenario based on the supplied STIX bundle.

1. Introduction

This exercise simulates a credential phishing campaign targeting university students, faculty, and staff. The campaign abuses trust in MFA reset communications, directs victims to a fake login portal, and results in unauthorized access to academic records and financial aid documents.

The scenario is discussion-based. Participants should respond according to their actual roles, procedures, escalation paths, and regulatory obligations. The goal is not to assign blame, but to identify decision points, communication needs, and improvement opportunities.

2. Exercise Scope

- Primary impacted environment: University Identity Provider, single sign-on, and MFA services.
- Primary data at risk: student academic records, financial aid documents, identity account data, and authentication factors.
- In-scope capabilities: detection, triage, identity containment, communications, legal/privacy assessment, notification planning, and recovery.
- Out of scope: live technical testing, attribution beyond the fictional actor, and real changes to production systems during the session.

3. Audience and Duration

- Recommended duration: 90 minutes, including introduction, four injects, and final debrief.
- Executive audience: crisis leadership, risk, legal/privacy, communications, student affairs, registrar/financial aid leadership.
- Operational audience: IT service desk, identity and access management, security operations, incident response, application owners.
- Technical audience: SOC analysts, email security, IAM engineers, forensic investigators, endpoint and network teams.

4. Exercise Objectives

- Validate escalation from phishing reports to a coordinated security and institutional response.
- Assess the ability to identify, contain, and recover from compromised student, faculty, and staff accounts.
- Clarify decision rights for forced password resets, MFA token revocation, session revocation, and temporary access restrictions.
- Evaluate privacy, legal, and communications workflows for potential exposure of student records.
- Test coordination among the SOC, identity team, IT service desk, registrar, financial aid, legal/privacy, communications, and university leadership.
- Identify improvements to email security, MFA resilience, phishing reporting, logging, and post-incident lessons learned.

5. Rules of Engagement

- Real incidents take priority. Participants may step away if operational needs require it.
- There are no right or wrong answers; the exercise is designed to surface assumptions, gaps, and improvement areas.
- Participants should respond using current policies, systems, roles, and escalation paths.
- Do not fight the scenario. Treat the scenario as fictional but plausible.
- Information is intentionally incomplete. Ask what you would request, from whom, and what decision would be made with that information.
- Facilitators may pause, accelerate, or clarify the scenario to keep discussion aligned with objectives.

6. Planning Assumptions

- The phishing campaign begins during a busy academic period, increasing help desk pressure and reputational sensitivity.
- The university has a centralized identity provider and MFA service used across student, faculty, and staff services.
- Some users approve MFA prompts or provide MFA information to the fake portal.
- Initial evidence suggests unauthorized access to records, but the exact scope is uncertain until log review is completed.
- The university must consider student notification obligations, regulator or education authority expectations, and law enforcement coordination.

7. Scenario Narrative

Threat actor: Campus Credential Phishing Actor. The actor targets Lakeside State University using emails that impersonate university IT and claim that MFA enrollment will expire unless users reset authentication settings. Victims are directed to a fake login portal that captures usernames, passwords, and MFA prompts.

Targeted infrastructure: University Identity Provider - Single sign-on and MFA service used by students, faculty, and staff.

As compromised accounts are used, audit logs show access to academic records and financial aid documents. The exercise culminates in a campus-wide response involving account containment, identity provider review, user communications, notification planning, and law enforcement coordination.

Business and Mission Impact Themes

- Disruption to student and faculty access if forced resets or MFA token revocations are broadly applied.
- Potential exposure of regulated or sensitive student records, requiring privacy and legal review.
- High-volume inquiries to the service desk, registrar, and financial aid offices.
- Media and community concern if students believe their personal or financial aid data has been accessed.
- Need to preserve evidence while restoring trust in university authentication services.

Key Exercise Roles

Role	Expected focus
Crisis Lead / Executive Sponsor	Set priorities, approve major containment, manage institutional risk.
SOC / Incident Response	Triage alerts, collect evidence, define scope, coordinate containment.
IAM / Identity Platform Owner	Revoke sessions, reset credentials, review MFA tokens, harden authentication policies.
IT Service Desk	Manage user reports, support resets, communicate approved guidance.
Legal / Privacy	Assess exposure, notification duties, evidence preservation, law enforcement engagement.
Registrar / Financial Aid	Assess records accessed, operational impact, student-facing response needs.
Communications	Prepare internal, student, faculty, and external messaging.

8. Exercise Timeline and Injects

Suggested exercise clock: Day 1, 08:30 to Day 2, 16:00. Facilitators may adjust the clock to fit the session length.

Inject 1 - MFA Reset Phishing

Exercise time: Day 1, 08:30

Scenario update: Students and faculty report emails claiming that MFA enrollment will expire unless they reset their authentication settings through an embedded link.

Facilitator intent	Discussion questions	Expected actions
Confirm phishing report intake and triage ownership. Assess whether the message is still in mailboxes and whether the domain is active. Determine immediate user guidance and service desk scripting.	Who declares this a security incident and at what severity? What evidence is needed before campus-wide communications? How do you coordinate email takedown, domain blocking, and phishing reporting?	Email security review started; phishing indicators preserved; malicious messages searched and removed; phishing site submitted for takedown/blocking; initial internal advisory drafted.

Inject 2 - Fake Login Portal

Exercise time: Day 1, 10:15

Scenario update: IT identifies a fake university login portal collecting usernames, passwords, and MFA prompts from victims.

Facilitator intent	Discussion questions	Expected actions
Determine scope of credential capture and MFA abuse. Decide containment actions for known or suspected victims. Coordinate with IAM, service desk, and communications.	Do you force password resets only for known victims or a broader population? What MFA factors or sessions should be revoked? How do you avoid overwhelming students and staff during containment?	Victim list created; active sessions revoked for confirmed accounts; password reset and MFA token review initiated; phishing domain blocked; help desk workflow activated.

Inject 3 - Records Accessed

Exercise time: Day 1, 14:00

Scenario update: Audit logs show compromised student accounts used to access academic records and financial aid documents.

Facilitator intent	Discussion questions	Expected actions
Assess data exposure and business impact. Bring privacy/legal, registrar, and financial aid leadership into decision-making. Preserve logs and begin detailed access review.	What constitutes confirmed exposure versus suspicious access? Who owns the student records impact assessment? What notification thresholds, timelines, and approvals apply?	Impacted systems and data types identified; access logs preserved; legal/privacy assessment started; student records offices briefed; external counsel or insurer considered if applicable.

Inject 4 - Campus-Wide Response

Exercise time: Day 2, 09:00

Scenario update: University leadership authorizes a forced password reset, MFA token review, student notification planning, and law enforcement coordination.

Facilitator intent	Discussion questions	Expected actions
Authorize campus-wide containment and recovery actions. Align public messaging, notification planning, and law enforcement coordination. Define post-incident monitoring and lessons-learned actions.	Who approves a forced password reset and MFA token review? What should students, faculty, and staff be told now? When should law enforcement, regulators, or education authorities be notified?	Leadership decision recorded; forced reset plan approved; staged communications released; law enforcement coordination evaluated; monitoring plan and post-incident report assigned.

9. Critical Decision Points

- Incident severity: decide when phishing becomes a declared cyber incident and who has authority to escalate.
- Containment scope: decide whether to reset credentials and revoke MFA factors for confirmed victims, high-risk groups, or the full campus.
- Access continuity: balance user disruption against the risk of ongoing unauthorized access.
- Evidence preservation: ensure logs, phishing emails, domain details, and identity-provider audit records are retained before cleanup.
- Notification posture: determine when evidence supports student notifications and external coordination.
- Public messaging: align communications so students receive clear, actionable instructions without increasing panic.

10. Technical Impact Considerations

- Compromised credentials and active sessions may remain valid after password reset unless sessions are explicitly revoked.
- MFA fatigue or adversary-in-the-middle phishing may bypass basic MFA if token/session controls are weak.
- Identity-provider audit logs are essential to determine which records were accessed and whether access was anomalous.
- Email gateway, DNS, endpoint, and web proxy logs can help identify recipients, clickers, and repeat access to the phishing portal.
- Recovery should include review of suspicious MFA device registrations, app passwords, OAuth grants, mailbox rules, and delegated access.

11. Business, Legal, and Communications Considerations

- Student trust may be affected even before confirmed data exposure; communications should clearly distinguish confirmed facts from investigation status.
- Registrar and financial aid offices may need surge support for student inquiries.
- Privacy and legal teams should assess whether accessed academic and financial aid documents trigger notification obligations.
- Leadership should determine whether campus-wide password reset timing conflicts with academic deadlines, exams, registration, or aid processing.
- External coordination may include law enforcement, cyber insurance contacts, sector partners, and relevant regulators or education authorities.

12. Facilitator Guide

Facilitators should encourage participants to describe who does what, what information is required, and what artifact or decision is produced at each stage. Capture gaps as observations, not failures.

Prompts to Use Throughout

- What do you know, what do you assume, and what do you need to confirm?
- Who is the accountable decision-maker for this step?
- What message goes to students, faculty, staff, leadership, and external stakeholders?
- What logs, evidence, or approvals must be preserved?
- What would change if the number of compromised accounts doubled?

Exercise Evaluation Criteria

Capability	Strong performance indicators
Detection and triage	Reports are correlated quickly, phishing indicators are captured, and incident severity is set consistently.
Containment	Sessions, passwords, and MFA factors are addressed in the correct order with clear ownership.
Governance	Crisis leadership, legal/privacy, registrar, and financial aid are engaged at appropriate points.
Communications	Guidance is timely, accurate, audience-specific, and coordinated through approved channels.
Recovery	Monitoring, user support, lessons learned, and post-incident reporting are assigned with owners and due dates.

13. Debrief and Lessons Learned

Use the final debrief to convert discussion into concrete improvement actions. Assign an owner and target date for each action.

- What worked well in the first 30 minutes of the response?
- Where were roles or decision rights unclear?
- Could the identity team revoke sessions, reset credentials, and review MFA tokens fast enough?
- Was the service desk prepared for high-volume MFA and password reset support?
- Were privacy, legal, registrar, financial aid, and communications engaged at the right time?
- What controls would reduce the likelihood or impact of this scenario?

Recommended Improvement Backlog

Area	Recommended action
Identity security	Implement phishing-resistant MFA for high-risk users and review conditional access/session revocation procedures.
Logging	Confirm identity-provider, student records, financial aid, email, DNS, and proxy logs are retained and searchable.
Response playbooks	Update phishing and account compromise playbooks to include MFA token review, OAuth grant review, and mass reset decision criteria.
Communications	Prepare pre-approved templates for phishing alerts, password resets, and student record exposure investigations.
Training	Run targeted awareness for MFA reset scams and safe reporting channels.
Governance	Document escalation thresholds for privacy/legal and leadership involvement in student data incidents.

14. MITRE ATT&CK Mapping

The following mapping reflects the tactics, techniques, and sub-techniques represented in the exercise scenario. The STIX bundle explicitly identifies T1566 Phishing and T1078 Valid Accounts; additional sub-techniques below are scenario-consistent interpretations for facilitation purposes.

Tactic	Technique / sub-technique	Scenario expression	Discussion focus
Initial Access	T1566 - Phishing	Emails claim MFA enrollment will expire and direct users to a malicious reset link.	Email detection, takedown, user reporting, awareness.
Credential Access	T1566.002 - Spearphishing Link	Users click an embedded link to a fake university login portal.	URL rewriting, block lists, domain takedown, warning banners.
Credential Access	Credential capture behavior	Fake portal collects usernames, passwords, and MFA prompts.	Phishing-resistant MFA, credential reset, evidence collection.
Defense Evasion / Persistence	T1078 - Valid Accounts	Compromised university credentials are used to access protected systems.	Session revocation, MFA factor review, account monitoring.
Discovery / Collection	Account and record access review	Audit logs show access to academic records and financial aid documents.	Scope analysis, data access review, privacy assessment.
Impact	Operational disruption through containment	Forced password reset and MFA review create campus-wide service pressure.	Business continuity, service desk capacity, communications.

Mapped STIX attack patterns: T1566 Phishing; T1078 Valid Accounts.